



ARKA HEALTH, INC.

WORKFORCE SECURITY TRAINING & SANCTION POLICY

Security awareness and training, 45 C.F.R. § 164.308(a)(5); sanctions, § 164.308(a)(1)(ii)(C) and § 164.530(e)

ARKA-SEC-008 · Version 1.0 · Confidential — Internal

Document No.	ARKA-SEC-008
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — Internal
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. TRAINING PROGRAM

1. **Onboarding.** Each Workforce Member shall complete privacy and security training — covering HIPAA fundamentals, this policy suite, phishing and social engineering, credential hygiene, incident reporting, and the prohibition on placing PHI in non-production environments — **before** being granted access to production systems, and in all cases within ten (10) business days of start.
2. **Annual refresher.** All Workforce Members complete refresher training every twelve (12) months, updated for the year's incidents, regulatory changes, and risk-analysis findings.
3. **Role-based modules.** Engineering personnel complete secure-development training (OWASP Top 10, secrets handling, dependency hygiene) annually; personnel with Customer-data access complete minimum-necessary and verification training (ARKA-PRIV-001, § 7).
4. **Security reminders.** Periodic reminders (at least quarterly) address current threats — credential phishing, MFA fatigue, vendor-impersonation fraud — per § 164.308(a)(5)(ii)(A).
5. **Records.** Completion records (person, module, version, date, attestation) are retained six (6) years and constitute audit evidence for TSC CC1.4 and HITRUST e1 training requirements.

2. ATTESTATION

Upon onboarding and at each annual refresher, each Workforce Member shall execute a written attestation acknowledging receipt and comprehension of this policy suite and agreeing to comply. Access shall be suspended for any Workforce Member whose training or attestation is more than fifteen (15) days overdue.

3. SANCTIONS

Violations of the Program are addressed through graduated, consistently applied sanctions, documented in each instance and retained for six (6) years:

Category	Illustrative conduct	Sanction range
Category I	Inadvertent, low-risk deviation promptly self-reported (e.g., missed screen lock; delayed training)	Documented coaching; targeted retraining
Category II	Negligent violation creating material risk (e.g., credential sharing; storing work data on personal unencrypted device; repeated Category I)	Written warning; access reduction; mandatory retraining; performance consequences
Category III	Willful or reckless violation (e.g., intentional unauthorized access to or disclosure of PHI; attempted re-identification; obstruction of an investigation)	Suspension or termination of employment/engagement; referral to law enforcement or regulators where warranted

Good-faith reporting of one's own error is a mitigating factor; concealment is aggravating. No sanction shall issue for reports made under the non-retaliation commitments of ARKA-GOV-001, § 7. Sanctions involving the Security Officer personally shall be determined by the Chief Executive Officer with advice of outside counsel; sanctions involving the Chief Executive Officer shall be determined by the Board of Directors.

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company's operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.

By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026